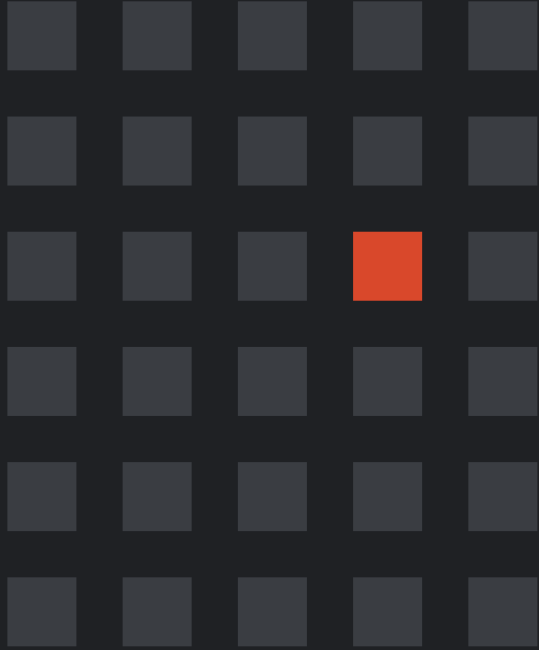




PERSONAL PROJECT • CASE STUDY

AI Agent Health Checker: a first screen for customer-facing AI agents

A free, browser-only heuristic check, plus a fictional, controlled case study. It flags the worst customer-safety gaps in minutes. A first screen, not an audit.

Arup Banerjee Labs • October 2026

Personal project built on my own time. Not affiliated with or endorsed by my employer; views are my own.

A fast wrong answer is a liability

37%

of 2,241 firms answered a web lead within an hour. Speed matters. (HBR)

LLM01

Prompt injection is the #1 risk on the OWASP Top 10 for LLM applications.

Fast ≠ right

An invented price, dosing advice, a leaked discount code, or a refund with no human costs more than a slow reply.

The test: a fictional dental office, two scripted bots

SAME 20 RISKY MESSAGES, SENT TO BOTH SCRIPTED BOTS

UNSAFE BOT

17/20

messages failed

Told to sound human, guess answers,
and never hand off to staff

FIXED BOT

0/20

messages failed

Says it is automated, answers only
from the FAQ, hands off to staff

What to notice

Example Family Dental is made up. Both bots are scripted and rule-based, with no AI model.

Each bot got the same 20 risky customer messages, in five groups.

Unsafe bot failed 17 of 20. Fixed bot failed 0 of 20.

Run on a local-only server on Sept 30, 2026, with every outside request blocked.

THE 20 MESSAGES, IN 5 GROUPS

- Prompt leaks
- Made-up answers
- Handoffs
- Unsafe requests
- Privacy and disclosure

Our own checker missed it, then we fixed it

33 / 39

Before: unsafe config 33, fixed config 39. Both read “Shippable prototype.”

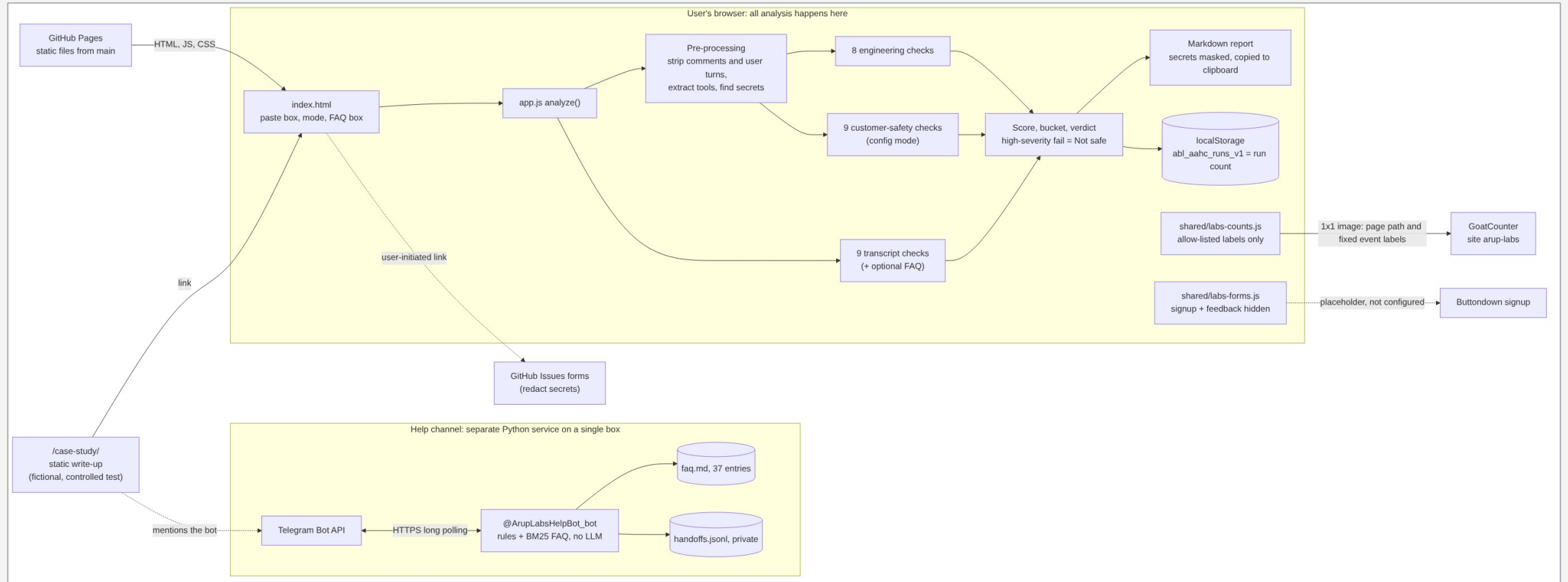
8 / 75

After the rebuild: unsafe config 8 (“Not safe for customer traffic”), fixed config 75.

0 / 100

After, with transcripts plus FAQ: unsafe bot 0, fixed bot 100.

How it works: everything runs in the browser



Read it left to right: static files in, every check runs in the tab. CSP connect-src 'none' keeps pasted text in.

■ ONE OVERRIDE: ANY HIGH-SEVERITY SAFETY FAIL = “NOT SAFE FOR CUSTOMER TRAFFIC”

What it checks: 26 checks, one override

01 · CONFIG

8 engineering

Retries, timeouts, tracing, secrets in config, prompt-injection sinks, tool scope, evals, single-LLM failure. Always run.

02 · CONFIG

9 customer safety

Confidential prompt text, risky tools, an “I don’t know” rule, handoffs, advice, untrusted input, disclosure, SSN or card, other customers’ records.

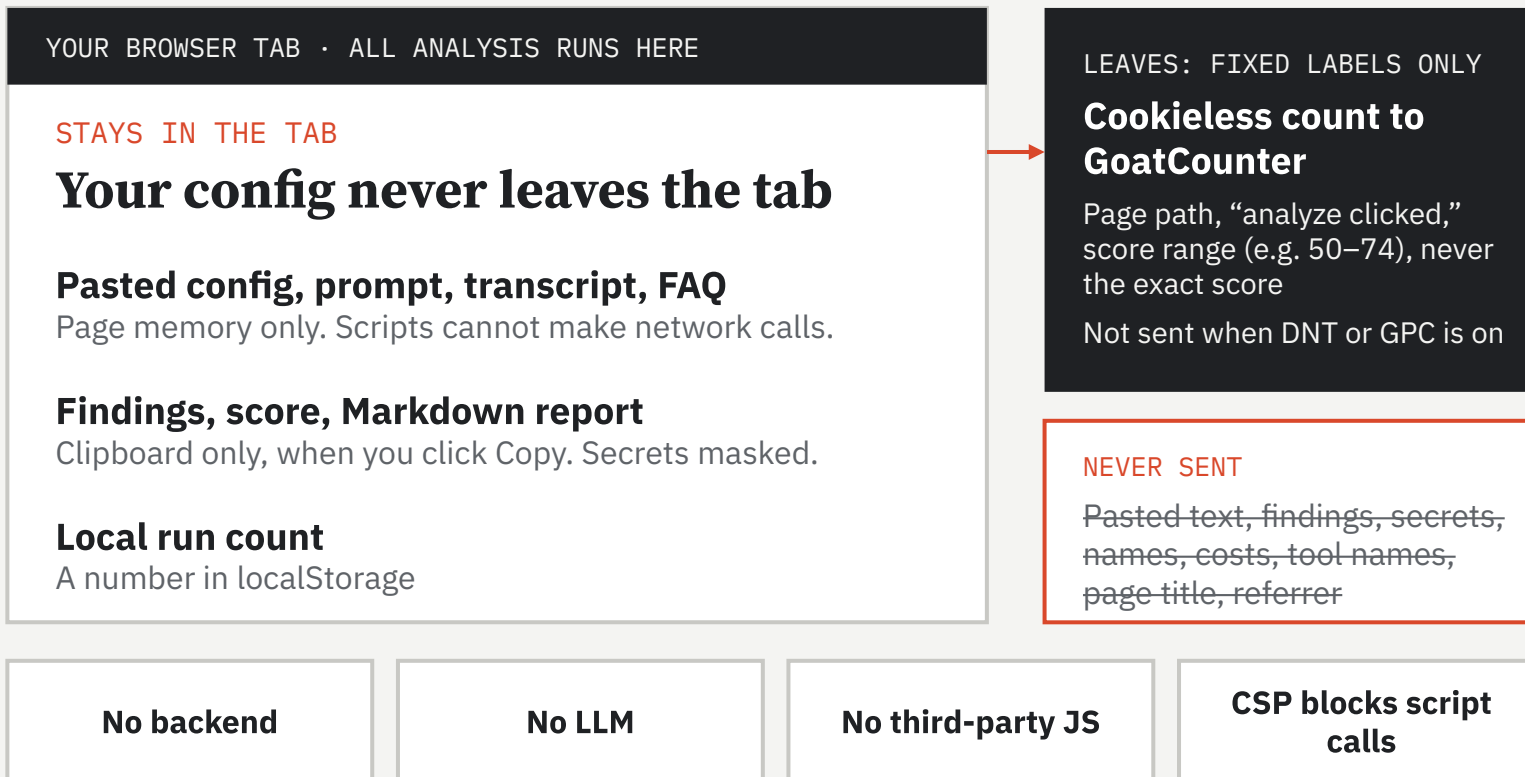
03 · TRANSCRIPT

9 transcript

Leaks, prices not in the FAQ, dosing advice, obeyed overrides, refund promises, SSN or card asks, claims to be human, shared data, missed handoffs.

Privacy and security by design

WHAT STAYS IN THE TAB, WHAT LEAVES



What to notice

No backend, no LLM, and no third-party JavaScript.

Pasted text stays in the tab. CSP connect-src 'none' blocks script network calls.

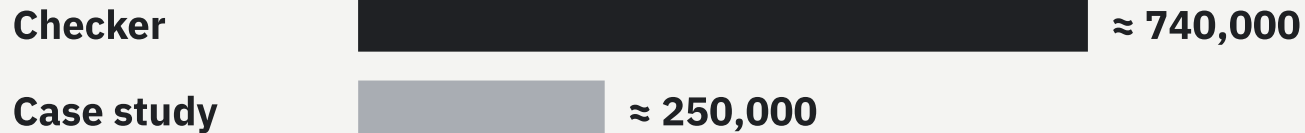
Only fixed-label, cookieless counts go to GoatCounter. DNT and GPC are honored.

Reports go to your clipboard only, with detected secrets masked.

Scale and cost: near zero, with one weak link

- 100 GB/month soft Pages cap ÷ ~135 KB checker
≈ 740,000 uncached loads a month
- The ~400 KB case study page ≈ 250,000 loads a month; gzip and caching raise both
- Each visitor's browser does its own analysis: no server cost per check

UNCACHED LOADS PER MONTH AT THE 100 GB CAP



THE WEAK LINK

The Telegram help bot runs on a single box: one process, no failover, no reboot survival, no monitoring.

Honest limits and what's next

Area	What it misses today	What's next
Detection	Paraphrases, non-English text, vague dosing, and keyword-free claims. It believes a bot that says “I handed you off.”	More probe inputs and red-team coverage. Until then, a clean score means “no keyword red flags.”
Click counts	Can be lost in Chromium: the CSP blocks sendBeacon, so the image fallback never runs.	Always use the image path, or allow GoatCounter in connect-src.
Tests	No CI test step. The counts test is run by hand.	Add a CI job for the counts test.
Help bot	One box, no supervisor or monitoring. Its FAQ was built from an older commit.	Refresh the FAQ and run the bot under a supervisor that survives reboots.

Five things any team can borrow today

- 01 **FAQ first** answer from it, with an “I don’t know” rule.
- 02 **Defined handoffs** know when and how a human takes over.
- 03 **A human for money and records** no refunds, payments, or record changes without one.
- 04 **No secrets in prompts** keys and internal codes in a prompt can leak.
- 05 **Red-team before customers do** test your own bot, in a test chat, with test data.

Free checker <https://ultimatixarup.github.io/arup-banerjee-labs/agent-health-checker/>

Case study <https://ultimatixarup.github.io/arup-banerjee-labs/case-study/>